ISA/IEC 62443-3-3 / 4-2 - SL-3 TESTING CHEAT SHEET

ABB 2600T Series 266 WirelessHART Pressure Transmitter (WirelessHART variant, output code W/9; sub-models 266DSH/266NSH/266HSH/266PSH/266MSH - e.g., 266DxH, 266HxH, 266NxH) - Component type: Embedded Device (EDR) - Target SL = SL 3

Where to work	Four assessment surfaces, all local/near-field (no IP on the device): (1) **Integral LCD HMI + 4-button keypad** / **TTG through-the-glass keypad** - menus **Easy Set-up / Device Set-up / Display / Calibrate / Diagnostics / Device Info / Communication** (Communication holds Network ID, Join Key, Tag, HART Long-Tag; Display holds the optional protection password; Device Set-up holds Write Protection + reset-to-default; wake HMI by pressing **Z >2s** under the ID plate). (2) **HART handheld terminal** (ABB **DHH805**, Emerson **375/475**) running the **266 EDD (HART 7)** over the wired **FSK/HART maintenance loop** at the **Field Terminals** cover; poll multidrop/short-address **1**; nav **DD navigation -> Wireless Config -> Network Settings -> Network Setup**. (3) **PC/laptop DTM in an FDT frame** or **ABB Asset Vision Basic v1.00.17+** via a **HART modem** to the loop terminals (or wirelessly through the gateway); config backup via **File_Save** (offline config DB). (4) **Physical inspection** of the hardware **write-protect pushbutton** (press+turn 90 deg CW to enable) and the **DIP switches SW1/SW2** (replace mode) under the identification nameplate. NO on-device audit log, filesystem, web UI, CLI, or NTP - IP/TLS/port/syslog/time-sync testing is performed on the **separate WirelessHART Gateway**, not this transmitter.
Interfaces / ports	**Wireless (primary):** WirelessHART (HART 7) over **IEEE 802.15.4 PHY, 2.4 GHz ISM**, **TDMA (100x10 ms slots/s) + FHSS** across 15/16 channels with channel blacklisting, self-organizing mesh (graph + source routing); radio **FCC ID 2AC5O-WICB / IC 12311A-WICB**. **Wired maintenance: FSK/HART** 4-wire loop under the Field Terminals cover (local DTM/handheld), default HART polling/short address **1** (multidrop). **Local physical:** LCD HMI keypad, TTG keypad, Z/S push buttons, hardware write-protect switch, replace-mode DIP switches SW1/SW2. **NO IP/Ethernet, NO TCP/UDP ports, NO SNMP/SSH/HTTPS/Modbus/HART-IP/syslog/NTP on the transmitter.** Those IP services (e.g., Modbus TCP **502**, HART-IP **5094**, TLS wrapper to host) reside on the upstream **WirelessHART Gateway** - assess them against 62443 on the gateway, cross-referenced here.
Firmware / revisions	Exact WirelessHART firmware version NOT stated in ABB docs - **ASSUMPTION / obtain at assessment time**: read **HW Rev** and **SW Rev** from the nameplate and the **Device Info** HMI menu (sensor type, hardware revision, software revision, display revision), and the driver revision from the **DTM/EDD 'About'** screen (related 266 HART DTM history references rev **7.1.50, 02/2013** - confirm the WirelessHART build separately). Operating instruction of record: **OI/266/WIHART-EN Rev. C (2019)**. Confirm EDD is **HART 7** capable and DTM/FDT frame + **Asset Vision Basic >= v1.00.17**. Signed-firmware / secure-boot / tamper-detection status is **NOT documented by ABB - treat as unverified; request confirmation from ABB PSIRT.**
How to read	One row per requirement: **SR/CR x.y** where system+component apply, **CR x.y** or **SR x.y** where only one applies, **EDR x.y** for embedded-device-specific rows (augmenting rows read e.g. 'SR/CR 1.13 (+ EDR 1.13)'). The verify cell gives the exact **native menu path / action** in bold, often a short **Test:** action, then **Ext. tools:** naming the specific external tool with its command/flags or click-path. **pass** = the crisp, capturable evidence/criterion. **notes** = firmware/model caveat or control class (**Compensating**, **Partial + compensating**, **EDR-specific**, **Gateway-scope**). Because this is a symmetric-key field device with no login, many IAC controls are met by **key management + physical write-protect + gateway/host compensating controls** - those are marked Partial/Compensating with the compensating step given, never merely 'not supported'. Non-applicable controls (e.g., wired-only clauses, person-to-person, application partitioning on a single-purpose device, facility emergency power) carry a one-line justification and pass = '**N/A** - justification recorded (not assessed as a control)'. All external testing is LOCAL/near-field via HART modem/handheld or ISOLATED-lab radio; no destructive tests on a live SIL-rated loop without an authorized maintenance window.

FR 1 - Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user identification and authentication	Device has **no user accounts/login/RBAC** - local **LCD HMI keypad**, **TTG**, **Z/S push buttons**, **HART handheld** (DHH805/375-475) and **DTM/Asset Vision Basic** all grant config access without per-user auth. Only mitigations are the **hardware write-protect switch** (under ID nameplate, turn 90° CW) and optional **protection password** in **Display** menu. **Test:** connect DTM over the FSK/HART loop terminals - confirm read/write with no credential prompt. **Ext. tools:** ABB **Asset Vision Basic v1.00.17+** / **FDT-frame DTM** via HART modem; physical inspection of write-protect switch + ID plate holding screw.	Write-protect switch engaged, Display protection password set, and physical/electrical access to loop terminals restricted (locked enclosure/marshalling cabinet); no unauthenticated write path left open.	EDR-specific. Partial + compensating - field instrument has no human-user IA; enforce human IA at the EWS/DTM host login, AD/IdP, and physical access control. Confirm password behaviour vs FW/EDD rev from DTM 'About'.
SR/CR 1.2	Software process and device identification and authentication	Device-to-network auth is **symmetric-key WirelessHART**: joining requires matching **Network ID** (16-bit) + **Join Key** (128-bit) - set via **Communication -> Wireless Config -> Network Settings**. On the wired **FSK/HART** maintenance port the device answers at **poll/short address 1 (multidrop)** with no authentication. **Test:** in DTM read **Join Status / 'Join complete'** flag to confirm the device authenticated to the network manager; on wired port confirm handheld reads PVs at address 1 with no key.	Device joins only with the correct per-device Join Key + Network ID (evidence: Join complete flag); wired HART port physically protected since it accepts unauthenticated HART cmds.	EDR-specific. WirelessHART join = device authentication; wired FSK port is unauthenticated by protocol -> compensate with physical/loop access control.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.3	Account management	**N/A.** The 266 transmitter has **no local account database, no roles, no add/modify/disable/remove of accounts** - it is a single-purpose field instrument with key-based network access only. Account management for the DTM/EWS host and the upstream WirelessHART gateway/DCS is done there.	**N/A** - justification recorded (not assessed as a control)	**N/A** on device. Compensating: manage accounts on EWS/AD and gateway/800xA.
SR/CR 1.4	Identifier management	Manage device identifiers via **Communication/Easy Set-up**: unique **HART Long-Tag** (32-char, default from serial number - required for Asset Vision/Ethernet), **HART Tag**, **poll address**, and **Network ID**. **Test:** in DTM/handheld read **Long-Tag** and confirm it is plant-unique and distinct from the network name; verify Network ID matches the intended network only.	Each transmitter has a unique, documented Long-Tag/Tag; Network ID assigned per site plan; identifiers recorded in asset register.	EDR-specific. No human-user identifiers exist; device/tag identifiers only.
SR/CR 1.5	Authenticator management	**Critical:** replace the **default/hardcoded Join Key** HEX `57495245 4C455353 4649454C 444B4559` (ASCII 'WIRELESSFIELDKEY') and default **Network ID 0xABB (2747)**. Enter new key in **Communication -> Wireless Config -> Network Setup -> Key 1-4 (HEX, caps 0-9/A-F)** via handheld/DTM/HMI; mandate **per-device unique Join Keys**. Join Key is **write-only (cannot be read back)** - positive control. Enable **key rotation** per plant policy at the network manager/gateway. **Test:** attempt to read Join Key from LCD/handheld -> must be non-readable; attempt join with old default key -> must fail. **Ext. tools:** WirelessHART gateway security-manager UI for network/session-key rotation policy; DTM **Extras -> Network Settings** to program keys.	Default Join Key and Network ID changed; unique per-device Join Keys provisioned; key not readable from device; rotation policy configured and evidenced.	EDR-specific, highest-priority SL-3 finding. Default common join key is publicly known - reject as fail if unchanged.
SR/CR 1.6	Wireless access management	WirelessHART is the primary interface - authorize/authenticate joining devices at the network manager via **Network ID + per-device Join Key**; require **Active Advertising** only during commissioning then disable, and restrict which devices may join. Set **Join Mode** ('Join Now') deliberately, verify **>=3 neighbors** and link/signal in **DTM Network Diagnostics**. **Test:** power a rogue node with wrong Join Key within RF range -> confirm it is denied (no Join complete). **Ext. tools:** IEEE 802.15.4 2.4 GHz survey with **Ubiqua/Perytons 802.15.4 analyzer** + **TI CC2531/Ubertooth-class sniffer** (passive) to confirm only authorized nodes transmit; WirelessHART **gateway security manager** for access-control list / accept-list.	Only devices with valid unique Join Key + Network ID join; advertising disabled post-commissioning; rogue-join test denied; neighbor/link diagnostics healthy.	EDR-specific; wireless applies (WirelessHART variant). AES-128 CCM always on secures the link.
SR/CR 1.7	Strength of password-based authentication	**N/A (as a device password policy).** The transmitter has **no login password with configurable strength policy** - only an optional numeric **Display protection password** (local HMI lock, not a network authenticator) and a symmetric Join Key (covered by CR 1.14). No enforceable min-length/complexity/history mechanism exists on-device.	**N/A** - justification recorded (not assessed as a control)	**N/A** on device (key-based). Compensating: enforce password policy on EWS/DTM-host and gateway login via AD GPO.
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A.** WirelessHART on the 266 uses **symmetric AES-128 keys only** - no X.509 certificates, no PKI, no certificate stores on the transmitter. Any TLS/PKI exists only on the upstream gateway->host (HART-IP/TLS wrapper), not this device.	**N/A** - justification recorded (not assessed as a control)	**N/A** on device. If gateway uses TLS, assess PKI there with testssl.sh/sslyze.
SR/CR 1.9	Strength of public key authentication	**N/A.** No public-key authentication on the transmitter (symmetric-key WirelessHART model; no private keys, no certificate validation). Not applicable to this EDR.	**N/A** - justification recorded (not assessed as a control)	**N/A** on device - see CR 1.14 for symmetric-key strength.
SR/CR 1.10	Authenticator feedback	The primary authenticator (**Join Key**) is inherently protected - it **cannot be read back** from the LCD/HMI or handheld and is entered write-only in **Key 1-4** fields. If a **Display protection password** is used, confirm entry is masked/not echoed on the LCD. **Test:** navigate **Communication -> Wireless Config -> Network Setup** and attempt to display the Join Key -> must show no value; observe password entry on HMI is obscured.	Join Key non-readable on all local/handheld interfaces; any HMI password entry is obscured (evidence: screenshot/photo of masked field).	EDR-specific - strong native control (positive: key non-readable).
SR/CR 1.11	Unsuccessful login attempts	**N/A (no login).** The transmitter has no interactive login to lock out. WirelessHART join failures (**F205.014 Join Failure**) are handled by the network manager, and the always-on AES-128 CCM MIC rejects forged/replayed frames rather than counting attempts. Brute-force of a 128-bit AES join key is computationally infeasible. Do **not** run Hydra/Medusa against the device (no login surface).	**N/A** - justification recorded (not assessed as a control)	**N/A** on device (no auth lockout concept). Lockout/backoff assessed on gateway/EWS if present.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.12	System use notification	**N/A.** No console/login session exists to present a banner; the LCD is a fixed process-value/menu HMI with no configurable use-notification text. System-use notification must be presented at the EWS/DTM host and gateway login.	**N/A** - justification recorded (not assessed as a control)	**N/A** on device. Compensating: configure logon banner on EWS/gateway.
SR 1.13	Access via untrusted networks	The transmitter exposes **no IP/untrusted network** - its only external network is the AES-128-secured WirelessHART mesh; there is no Ethernet/TCP-UDP stack, web, SSH or SNMP on the device. Control access at the boundary: harden and segment the **WirelessHART gateway** (Modbus TCP 502 / HART-IP 5094 / TLS to host) behind a firewall/DMZ, and physically protect the wired FSK/HART loop. **Test:** verify no IP services on the transmitter and confirm all remote DTM access transits the monitored gateway. **Ext. tools:** passive OT monitoring **Nozomi Guardian / Claroty / Tenable.ot** on the gateway SPAN to flag remote access; **nmap -sS -sU** run **against the GATEWAY only** (not the transmitter) to confirm exposed ports.	Transmitter confirmed IP-less; gateway boundary controls (firewall rules, segmentation, monitoring) documented and effective for remote/untrusted access.	EDR-specific. Compensating at gateway - untrusted-network control is a boundary function, not a device function.
CR 1.14	Strength of symmetric key authentication	Verify the WirelessHART symmetric keys meet SL-3: **128-bit AES-128 CCM** join/network/session keys, **always-on, cannot be disabled**; entered as full **4×32-bit HEX** (32 hex chars). Confirm **default Join Key replaced with per-device unique random 128-bit values**, key **not readable back**, and **rotation** enabled at the security manager. **Test:** program a full-entropy per-device key, confirm join, then confirm the device rejects the old default key; passively confirm all traffic is encrypted (no plaintext HART payload). **Ext. tools:** WirelessHART **gateway security manager** for key length/rotation config; **Ubiqua / Perytons 802.15.4 analyzer** (passive, isolated lab) to confirm AES-encrypted payload and MIC - no cleartext.	Unique 128-bit AES join keys (no default), non-readable, rotation policy set; sniffer shows only encrypted+MIC-protected frames; old-key join denied.	EDR-specific - primary FR1 authenticator for this device. Fail if default 'WIRELESSFIELDKEY' or a single shared network-wide key is in use at SL-3.

FR 2 - Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement - Enforce least-privilege authorizations for users/processes.	Transmitter has **no user accounts/RBAC/login**; access is gated by physical possession + the WirelessHART symmetric-key model (join/network/session keys) and the local **hardware Write-Protect switch** (under ID plate, press down + turn 90° CW). Confirm write-protect blocks config overwrite via **DTM/handheld** while leaving config read-only. **Test:** with Write-Protect ON, attempt a parameter write (e.g. **Parametrize_Differential Pressure Measurement**) from the DTM and confirm rejection ("! Oper Disabled"). **Ext. tools:** ABB **Asset Vision Basic v1.00.17+** / DTM in FDT frame over HART modem; **DHH805/Emerson 375-475** handheld with 266 EDD to attempt writes; compensating RBAC/least-privilege on upstream **Gateway** and **800xA/DCS host** (verify per-role accounts there).	Write-Protect ON demonstrably blocks all config writes from DTM/handheld/Z-S buttons while reads still succeed; per-device unique join key in use; host/Gateway enforces role-based least-privilege for engineering access.	EDR-specific: no on-device accounts (symmetric-key + physical write-protect). Full user authorization is Compensating at Gateway/host.
SR/CR 2.2	Wireless use control - Authorize/monitor/enforce usage restrictions for wireless.	Device joins only a network matching **Network ID** (default **0xABB / 2747**) AND a valid **128-bit Join Key** (default/hardcoded **57495245 4C455353 4649454C 444B4559** = 'WIRELESSFIELDKEY' - MUST be replaced with per-device unique key). Set via **Communication -> Wireless Config -> Network Settings** (HMI/handheld/DTM); enforce **Active Advertising/allow-list** at the Gateway so only whitelisted devices join. **Test:** confirm device with wrong Join Key gets **F205.014 Join Failure**; on the Gateway, verify device is on the accept-list. **Ext. tools:** ABB DTM **Network Diagnostics** (signal/neighbors, 'Join complete' flag); **Gateway web/config UI** device allow-list; passive OT monitor **Nozomi Guardian / Claroty CTD** on Gateway uplink for rogue-device/anomaly alerts; **802.15.4 spectrum sniffer (Ubiqua/Perytons + Texas Instruments CC2531)** in ISOLATED lab to confirm frames are AES-encrypted and only authorized devices associate.	Default Join Key changed to per-device unique value; Gateway allow-list enforced; unauthorized/wrong-key device denied (F205.014); wireless traffic confirmed AES-128 CCM encrypted; monitor alerts on rogue join attempts.	Core wireless control. SL-3 mandates per-device unique join keys - common/default key is a published, known weakness.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.3	Use control for portable and mobile devices - Control use of portable/mobile devices.	Only sanctioned mobile tools connect: **DHH805 / Emerson 375-475 handheld** with the 266 EDD, or a laptop with **DTM/Asset Vision Basic** via HART modem to the **FSK maintenance loop terminals** (under 'Field Terminals' cover). Enforce via physical access control to the wired terminals + **Write-Protect ON** so a maintenance laptop cannot alter config. **Test:** connect an unmanaged handheld and confirm it can read but not write while Write-Protect engaged. **Ext. tools:** procedural policy + physical lock/seal on housing cover; **Gateway/host endpoint control** (device-control/USB policy on the EWS running Asset Vision, e.g. Windows GPO / CIS-CAT baseline) for the PC side.	Handheld/laptop access is physically controlled and read-only when Write-Protect ON; EWS running DTM/Asset Vision hardened against unmanaged storage; procedure recorded.	Compensating: mobile-device governance sits on the maintenance PC/handheld and physical access, not on the transmitter.
SR/CR 2.4	Mobile code - Control and monitor the use of mobile code.	**N/A at device.** The transmitter runs fixed embedded firmware with **no filesystem, no scripting/mobile-code engine, no downloadable executable content**; DTM/EDD are static device descriptions parsed on the PC, not code executed on the transmitter. Control mobile code where it can run - the **Asset Vision/DTM host PC** (application allow-listing, block macros/ActiveX).	**N/A** - justification recorded (not assessed as a control); mobile-code controls applied on DTM host PC where applicable.	**N/A** on device; DTM/EDD execute on host PC only.
SR/CR 2.5	Session lock - Lock sessions after inactivity.	No IP/interactive login session exists on the device. Local HMI auto-reverts to measurement view after inactivity and requires **press Z >2s to wake**; optional **protection password** (Display menu) gates HMI menu changes. **Test:** leave HMI idle, confirm it drops back to the operating display and password is re-prompted. **Ext. tools:** verify DTM/handheld session; enforce screen-lock/timeout on the **Asset Vision Basic EWS** (Windows inactivity lock via GPO, validate with **Lynis/CIS-CAT** Windows baseline).	HMI returns to operating display on inactivity and re-prompts protection password; DTM host PC has an enforced inactivity lock.	Partial: device HMI timeout only. Interactive-session lock is Compensating on the EWS.
SR/CR 2.6	Remote session termination - Terminate remote sessions after inactivity or on demand.	Device has **no remote IP session** to terminate (no TCP/UDP stack). Remote engineering flows over the **Gateway** (HART-IP 5094 / Modbus TCP 502 / TLS to host); terminate/deauthorize there. On-device, **Extras -> Lock/Unlock Device** and Write-Protect provide on-demand blocking of remote writes. **Ext. tools: Gateway admin console** to drop/expire remote sessions; validate TLS session teardown on Gateway uplink with **testssl.sh --sneaky <gw>:5094** and session timeout config review.	Remote (Gateway) sessions expire on inactivity and can be terminated on demand; device Lock/Write-Protect blocks remote writes on demand.	Compensating at Gateway - no remote session terminates on the transmitter itself.
SR/CR 2.7	Concurrent session control - Limit the number of concurrent sessions.	WirelessHART uses **per-device end-to-end sessions** managed by the Network Manager; the transmitter serves one field connection at a time via the HART maintenance port (single **poll address 1**, multidrop) and there is no multi-user login. Concurrency limits belong to the **Gateway/Network Manager**. **Test:** attempt two simultaneous DTM connects to the same loop and confirm only one succeeds. **Ext. tools:** review **Gateway/Network Manager** session/connection limits in its config UI; DTM connection log.	Only one management connection active at a time on the wired port; Gateway enforces concurrent-session limits for remote access.	Partial + compensating: single-session at device; concurrency policy at Gateway.
SR/CR 2.8	Auditable events - Generate audit records for security-relevant events.	**No on-device audit log.** Device provides diagnostic/operational history only: **Diagnostics** (NAMUR NE107 codes XA.BBB, e.g. F205.014 Join Failure, F210.015 Radio Failure) and **Device Info -> Historic Info** (power-on count, total working time, min/max pressure/temp) - not tamper-evident, no user/action attribution. **Test:** trigger a join failure and confirm it surfaces as F205.014 on HMI/DTM. Security audit must be captured upstream. **Ext. tools: Gateway syslog -> SIEM (Splunk/Wazuh/QRadar)** for join/deny/config events; passive **Nozomi/Claroty** on Gateway uplink to log device add/removal and anomalies.	NE107 diagnostics observable at HMI/DTM; security-relevant events (joins, config changes, denials) logged with timestamps at Gateway/SIEM and retained per policy.	Compensating: device has no audit trail. Audit is Gateway/host/SIEM responsibility.
SR/CR 2.9	Audit storage capacity - Provide sufficient audit storage and handling.	**N/A at device** - no audit log store on the transmitter (only fixed-size Historic Info counters that overwrite on Reset). Size and retention of audit storage handled at the **Gateway/SIEM**. **Ext. tools:** configure SIEM (**Splunk/Wazuh**) index retention & disk-full handling for Gateway logs; verify Gateway log-buffer/rotation settings in its admin UI.	**N/A** - justification recorded (not assessed as a control); Gateway/SIEM sized for required retention with overflow handling.	**N/A** on device; Compensating at Gateway/SIEM.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.10	Response to audit processing failures - Handle audit processing failures safely.	**N/A at device** - no audit subsystem to fail. Device instead fails-safe on internal faults: NE107 **F-class** failures (e.g. F240.024/025 confdb/factparam corruption -> Master Reset/reload, F210.015 Radio Failure) drive configured alarm output and LCD warning. **Ext. tools:** verify Gateway/SIEM (**Wazuh/Splunk**) alert on log-pipeline failure/queue-full; confirm Gateway raises an event if it stops receiving from the device.	**N/A** - justification recorded (not assessed as a control); device fails safe on internal faults; Gateway/SIEM alerts on audit-pipeline failure.	**N/A** on device audit; device fault-handling verified separately. Compensating at Gateway.
SR/CR 2.11	Timestamps - Provide reliable, protected timestamps for audit records.	**No user-settable clock / no NTP** on the transmitter; time is provided by the **WirelessHART Network Manager via TDMA slot synchronization** (protected within the AES-secured mesh, not exposed as a config). Historic Info counters are elapsed-time based, not wall-clock. Wall-clock timestamps for audit come from the **Gateway/host** synchronized to a trusted source. **Ext. tools:** verify **Gateway NTP/time source** (e.g. authenticated NTP) and that SIEM records use synchronized time; check Gateway config UI.	Device time is Network-Manager TDMA-synced (integral to encrypted mesh); Gateway/SIEM timestamps sourced from a protected, synchronized clock.	Partial: no NTP on device by design. Trusted wall-clock timestamps Compensating at Gateway/host.
SR/CR 2.12	Non-repudiation - Provide non-repudiation for critical user actions.	Device cannot attribute actions to a user (no accounts, no signed action log). Non-repudiation compensations: **per-device unique Join Key** binds the physical device identity to the network; **hardware Write-Protect** + physical ID-plate seal restrict who can change config; critical write actions logged (with operator identity) at the **Gateway/host** engineering client. **Test:** confirm a config change made via DTM appears as an attributable event in the host/Gateway change log. **Ext. tools: 800xA/DCS audit trail** and **SIEM (Splunk)** correlation of engineering-client user to config-change events.	Config changes attributable to an identified operator at the Gateway/host with timestamp; device identity bound via unique Join Key; physical seal/Write-Protect logged.	Compensating: no device-level non-repudiation; attribution at host/EWS + physical controls.
EDR 2.13	Use of physical diagnostic and test interfaces - Protect physical debug/test interfaces (JTAG/UART).	No externally exposed JTAG/UART/USB is documented; service/config interfaces are the **FSK/HART maintenance loop terminals** (under 'Field Terminals' cover) and the **replace-mode DIP switches SW1/SW2** (inside housing) - both behind a screw-secured IP67 enclosure. **Test:** open housing, physically inventory internal headers/pads; confirm DIP replace-mode is OFF (SW1 pos.0) in normal operation and covers/seals intact; engage **Write-Protect** and seal the ID plate. **Ext. tools:** physical inspection + **tamper-evident seals**; if unpopulated debug pads are found, request **ABB PSIRT** confirmation that JTAG/UART is disabled in production firmware; ISOLATED-lab **logic analyzer (Saleae)** probe of suspect pads during boot to confirm no interactive console.	No accessible interactive debug interface; maintenance terminals + DIP switches enclosed under sealed IP67 housing; Write-Protect on; tamper seals recorded; PSIRT confirmation of disabled JTAG/UART on file.	EDR-specific. Secure-boot/JTAG-lockdown not documented in ABB 266 materials - verify with ABB PSIRT; treat as unverified until confirmed.

FR 3 - System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	(not generated - use Refine to regenerate this requirement)		regenerate
SR/CR 3.2	Malicious code protection	(not generated - use Refine to regenerate this requirement)		regenerate
SR/CR 3.3	Security functionality verification	(not generated - use Refine to regenerate this requirement)		regenerate
SR/CR 3.4	Software and information integrity	(not generated - use Refine to regenerate this requirement)		regenerate
SR/CR 3.5	Input validation	(not generated - use Refine to regenerate this requirement)		regenerate
SR/CR 3.6	Deterministic output	(not generated - use Refine to regenerate this requirement)		regenerate
SR/CR 3.7	Error handling	(not generated - use Refine to regenerate this requirement)		regenerate
SR/CR 3.8	Session integrity	(not generated - use Refine to regenerate this requirement)		regenerate
SR/CR 3.9	Protection of audit information	(not generated - use Refine to regenerate this requirement)		regenerate
CR 3.10	Support for updates	(not generated - use Refine to regenerate this requirement)		regenerate

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
CR 3.11	Physical tamper resistance and detection	(not generated - use Refine to regenerate this requirement)		regenerate
CR 3.12	Provisioning product supplier roots of trust	(not generated - use Refine to regenerate this requirement)		regenerate
CR 3.13	Provisioning asset owner roots of trust	(not generated - use Refine to regenerate this requirement)		regenerate
CR 3.14	Integrity of the boot process	(not generated - use Refine to regenerate this requirement)		regenerate
EDR 3.2	Protection from malicious code	(not generated - use Refine to regenerate this requirement)		regenerate
EDR 3.10	Support for updates	(not generated - use Refine to regenerate this requirement)		regenerate
EDR 3.11	Physical tamper resistance and detection	(not generated - use Refine to regenerate this requirement)		regenerate
EDR 3.12	Provisioning product supplier roots of trust	(not generated - use Refine to regenerate this requirement)		regenerate
EDR 3.13	Provisioning asset owner roots of trust	(not generated - use Refine to regenerate this requirement)		regenerate
EDR 3.14	Integrity of the boot process	(not generated - use Refine to regenerate this requirement)		regenerate

FR 4 - Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality - Protect confidentiality of information at rest and in transit.	In transit: WirelessHART enforces always-on **end-to-end AES-128-CCM** (confidentiality + MIC) at the network/transport layer - cannot be disabled. Confirm the mesh is up via **DTM -> Network Diagnostics** (Join complete, >=3 neighbors) and that the device joined only after correct **Network ID + Join Key**. The only sensitive at-rest secret is the **Join Key**, which is write-only - confirm via **HMI -> Communication -> Network Setup** and **handheld -> DD navigation -> Wireless Config** that Key 1-4 read back as blank/masked (positive control). **Test:** attempt to read Join Key from LCD and DHH805 - must fail. **Ext. tools:** WirelessHART sniffer (TI SmartRF/CC2531 + Wireshark **hart_ip**/802.15.4 dissector) on 2.4 GHz - captured payloads must be ciphertext, not plaintext PV/config; ABB Asset Vision Basic v1.00.17+ to confirm masked key fields.	Wireshark capture of 802.15.4 mesh shows encrypted payloads (no cleartext PV/config); Join Key non-readable from LCD/handheld/DTM; MIC present on frames.	AES-128-CCM is mandatory/non-disable per HART 7. No general filesystem exposed; at-rest scope limited to keys/config in NV memory. EDR-specific.
SR/CR 4.2	Information persistence - Purge sensitive information from released resources.	On decommission or return-for-repair, purge network credentials: **HMI -> Device Set-up -> reset all parameters to default** (or **handheld Extras -> Load Factory Settings**) then re-provision a throwaway Join Key, or physically remove the electronics/comm board. Note Load Factory Settings restores the **hardcoded default Join Key WIRELESSFIELDKEY** - so a decommissioned unit must NOT be left in that state on a live plant. **Master Reset** is only a reboot and does not purge. **Test:** after factory reset, attempt to rejoin production network - must fail (key reverted to default). **Ext. tools:** DHH805/Emerson 475 with 266 EDD to confirm post-reset Join/Network params; DTM **File_Save** to snapshot config before wipe for evidence.	Documented purge procedure executed; device no longer holds live plant Join Key/Network ID; evidence that reset reverts to non-production default key.	Partial - no cryptographic-erase/zeroize command; purge = factory reset (reverts to known default key) or board removal. Track units in asset inventory. EDR-specific.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.3	Use of cryptography - Use validated cryptographic mechanisms.	Confirm crypto is **AES-128 in CCM mode** (confidentiality + authentication/MIC) per the WirelessHART/HART 7 / IEC 62591 standard - the only supported and non-configurable algorithm; no weak/legacy cipher option exists to disable. Record device **HW Rev/SW Rev** from **HMI -> Device Info** and DTM **About** (EDD/DTM history ref 7.1.50) to tie the crypto implementation to a firmware baseline, and check ABB PSIRT for advisories against that revision. Enforce **per-device unique 128-bit Join Keys** and enable **key rotation** per plant policy at the gateway/Network Manager. **Ext. tools:** ABB DTM/Asset Vision to read HW/SW Rev; HART Foundation IEC 62591 conformance/registration record as validation evidence; check NIST CAVP / vendor letter for the AES-CCM implementation (request from ABB PSIRT - no FIPS 140 module claim in docs).	Crypto confirmed as AES-128-CCM per IEC 62591; firmware/EDD revision recorded and checked vs ABB PSIRT; per-device unique join keys + rotation policy in force.	No FIPS 140-2/-3 validation or NIST CAVP cert stated in ABB 266 docs - request from ABB PSIRT; standards-conformance is the available evidence. EDR-specific.

FR 5 - Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation - Segment networks logically into zones and conduits.	The 266 transmitter has **no IP stack** and lives only on the **WirelessHART 2.4 GHz mesh**; its logical zone is defined by the **Network ID** (default **0xABB / 2747**) which isolates it from other co-located WirelessHART networks. In **HMI -> Communication** (or handheld **DD navigation -> Wireless Config -> Network Settings**) confirm the device carries the plant's dedicated Network ID and that field-device traffic egresses only through the **WirelessHART Gateway** (Modbus TCP 502 / HART-IP 5094) into its own DMZ/OT zone. **Test:** enumerate mesh membership and verify no cross-zone neighbors. **Ext. tools:** WirelessHART Gateway web UI device roster to confirm zone membership; **Nozomi Guardian / Tenable.ot** on a SPAN of the gateway-to-DCS link (passive) to draw the zone/conduit map and flag unexpected flows.	Device Network ID = plant-assigned unique value (not 0xABB); all field traffic funnels through the designated gateway into a segmented OT zone; passive monitor shows no cross-zone conduits from the transmitter.	EDR-specific. Network ID is a logical separator, NOT a security boundary (it is not secret) - real segmentation is at the gateway. Partial + compensating (gateway/firewall).
SR/CR 5.2	Zone boundary protection - Protect zone boundaries and control conduit traffic (deny by default).	**N/A at the transmitter** - the 266 is a battery field device with no routable interface and cannot filter/route traffic; it only sources AES-128-CCM WirelessHART frames. Boundary control is enforced upstream: on the **WirelessHART Gateway** restrict the **Access Control List / device whitelist** so only provisioned devices (correct Network ID + per-device Join Key) join, and place a **deny-by-default firewall** on the gateway's **Modbus TCP 502 / HART-IP 5094 / Ethernet** conduit to the DCS. **Test:** attempt to reach the DCS zone through the gateway from an unauthorized subnet. **Ext. tools: nmap -sS -p 502,5094 <gateway>** from outside the zone to confirm ports closed/filtered; **testssl.sh <gateway-host:port>** on the HART-IP TLS wrapper; firewall ruleset export reviewed against deny-by-default.	Transmitter has no conduit to filter (documented); gateway enforces device whitelist + deny-by-default firewall; nmap from unauthorized subnet shows 502/5094 filtered; TLS wrapper validated on gateway.	Compensating - enforced on WirelessHART Gateway + OT firewall, not on the 266. EDR-specific.
SR/CR 5.3	General purpose person-to-person communication restrictions - Restrict general-purpose messaging.	**N/A.** The 266 WirelessHART transmitter is a single-purpose SIL2/SIL3 field instrument with no email, chat, general-purpose messaging, user shell, or file-transfer service; its only payloads are HART 7 process/diagnostic commands (e.g. cmds 1/2/3/9/33/48) over the AES-secured mesh. No person-to-person communication path exists to restrict.	**N/A** - justification recorded (not assessed as a control)	**N/A**
SR 5.4	Application partitioning - Partition data/applications based on criticality.	**N/A.** The 266 is a single-function embedded pressure transmitter (one measurement application on fixed firmware); it does not host multiple applications or general-purpose compute to partition. Note only that safety-critical config integrity is protected separately by the **hardware write-protect switch** (under the ID nameplate, turn 90° CW) and by the **Join Key positive control** (cannot be read back via LCD/handheld), keeping the process/safety function isolated from casual reconfiguration. **Test:** confirm write-protect blocks Z/S and config overwrite while data stays readable via DTM.	**N/A** - justification recorded (not assessed as a control). (Optional evidence: write-protect engaged and confirmed to block writes.)	**N/A** - single-purpose device; no multi-application partitioning applicable. EDR-specific.

FR 6 - Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility - Provide read access to audit logs for authorized users.	**N/A at device - no audit log.** The 266 WirelessHART transmitter has no on-device audit trail, no filesystem, no NTP and no security-event log; only **Historic Info** (Device Info/Diagnostics: **No. Power On**, **Total working time**, **Min/Max pressure/temperature/static pressure**) and **NAMUR NE107** status codes (format XA.BBB, e.g. F240.024) are shown locally. These are operational counters, not a tamper-evident, timestamped audit log. **Compensating:** capture security-relevant events (join/rejoin, key changes, write-protect toggles, config writes) at the upstream **WirelessHART Gateway** and its host (e.g. ABB 800xA / Asset Vision Basic project via Ethernet/Modbus TCP 502) where read access can be granted to authorized users. **Test:** connect DTM/FDT (or DHH805/375-475 handheld) to the loop terminals and read **Historic Info** to confirm no per-event, time-stamped audit records exist; then confirm gateway/host logging is enabled and readable. **Ext. tools:** vendor **DTM in FDT frame / Asset Vision Basic v1.00.17+** (Online -> Diagnostics/Historic Info) to enumerate device counters; **Gateway web UI / syslog collector** (e.g. rsyslog/Graylog, or Nozomi/Claroty event export) to hold and expose the real audit log; **ReadOnlyEnum.py** (read-only) on the gateway host to inventory log paths/permissions.	Device confirmed to have no audit log (only Historic Info counters, evidenced by DTM screenshot); compensating gateway/host audit log exists, is time-synced, and is read-accessible only to authorized users (RBAC screenshot + sample export).	EDR-specific: field instrument has no audit-log capability. Partial + compensating (gateway/host). Confirm Historic Info fields from OI/266/WIHART-EN Rev. C and DTM 'About' at assessment.
SR/CR 6.2	Continuous monitoring - Continuously monitor for security events and anomalies.	**N/A on-device (compensating required).** The transmitter cannot self-monitor or emit SIEM alerts; it exposes health only via **NAMUR NE107** codes (F/M/O/C, XA.BBB) on the LCD and over WirelessHART (**HART cmd 48** additional device status, status byte quality codes 0x08/0x40/0xB0/0xC0), plus **Burst mode** (HART cmds 1/2/3/9/33/48) and **DTM Network Diagnostics** (signal strength/link for up to 5 neighbours, 'Join complete', >=3 neighbours recommended). Note the **Input Simulation (C160.030)** and burst spoof risk - monitor for simulation-active state as an anomaly. **Compensating:** continuously monitor the **WirelessHART mesh and gateway** for join failures (F205.014), radio failures (F210.015), unexpected rejoins/key changes, RSSI drops, packet flooding/desync and gateway-spoofing indicators, feeding a SIEM. **Test:** in DTM Network Diagnostics, force a link change (move/shield a neighbour) and confirm the anomaly is visible in mesh diagnostics; verify the passive OT monitor raises an event. **Ext. tools: ABB Asset Vision Basic / DTM Network Diagnostics** (Online -> Network Diagnostics) for per-device neighbour/RSSI health; passive OT IDS **Nozomi Guardian / Claroty CTD / Dragos / Tenable.ot** (SPAN/tap on the gateway?host segment, WirelessHART/HART-IP 5094 & Modbus TCP 502 parsing) to baseline traffic and alert on anomalies; **gateway alarm/event stream -> SIEM** (Splunk/Graylog) for continuous alerting; enable **key rotation** per plant policy and alert on rotation failures.	DTM/Network Diagnostics shows live neighbour/RSSI/join health and flags induced link change; passive OT monitor (Nozomi/Claroty/Dragos/Tenable.ot) baselined on the gateway segment and demonstrably alerts on join-failure/rejoin/flooding/simulation-active anomalies to the SIEM.	EDR-specific: no native security-event monitoring/alerting. Partial + compensating (mesh/gateway/OT-IDS). WirelessHART known weaknesses (flooding, gateway spoofing, desync) drive the monitoring use-cases; AES-128 CCM cannot be disabled.

FR 7 - Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial of service protection - Protect essential functions from DoS.	Essential function (pressure measurement + local 4-20 mA/LCD output) is **decoupled from the radio** - the sensor keeps measuring even if the WirelessHART mesh is jammed/flooded. WirelessHART **FHSS across 15/16 channels + channel blacklisting + TDMA** mitigate RF DoS; confirm blacklisting policy on the gateway/network manager. On device check **Diagnostics -> NAMUR NE107** for **F210.015 Radio Failure** / **F205.014 Join Failure** as DoS indicators. **Test:** RF-flood a shielded chamber and confirm the loop/LCD value holds and NE107 flags a comms fault, not a measurement fault. **Ext. tools:** ABB **DTM Network Diagnostics** (neighbor/link/latency per §7.9.1); HackRF One + GNU Radio (2.4 GHz jam, **ISOLATED anechoic/shielded lab only**); Wireshark + nRF52840 sniffer (802.15.4) to observe hop resilience.	Measurement/local output unaffected during RF flood; NE107 raises Radio/Join fault; gateway shows channel blacklisting active and mesh re-routes.	Essential function is analog/local; RF DoS affects only telemetry. Jamming test lab-only. FW per nameplate/DTM 'About'.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.2	Resource management - Manage resources to prevent exhaustion.	Device is a fixed-function embedded transmitter with **no IP stack / no listening TCP-UDP sockets** to exhaust; radio duty cycle bounded by **TDMA slot allocation (10 ms slots)** from the network manager. Constrain resource load by setting a conservative **Burst** config - **Communication/Easy Set-up -> Burst** - <=3 messages at a sane interval (2 s-60 min) to avoid over-allocating band/battery. Check **Diagnostics -> Historic Info** (Total working time, power-on count) and battery status for exhaustion. **Ext. tools:** ABB **DTM/handheld (DHH805, Emerson 375/475)** to read burst rate + battery lifetime; DTM **Network Diagnostics** to confirm no packet backlog/latency growth; nRF-Sniffer/Wireshark to confirm TX conforms to allotted slots (passive).	Burst <=3 msgs at policy interval; no unbounded TX; battery/working-time counters nominal; network manager caps slot allocation.	No CPU/memory/socket exhaustion surface (no OS/IP). Battery is the finite resource - monitor lifetime.
SR/CR 7.3	Control system backup - Support backup of critical files/configurations.	Back up full device configuration via **DTM/FDT frame** or **Asset Vision Basic v1.00.17+**: connect HART modem to loop (Field Terminals) or via gateway, then **File -> Save** to export the offline config (transfer function, LRV/URV, flange/O-ring/fill material, tags, burst, Network ID). Store the export on protected/encrypted media; **NOTE: Join Key is NOT included/readable-back** (positive control), so record it out-of-band in a sealed key-escrow. **Test:** export config, alter a param, re-import, verify restore. **Ext. tools:** ABB **DTM/Asset Vision Basic** File_Save (native backup); Git/hash the exported file (sha256sum) for integrity + version control of the backup.	Config export produced and successfully re-imported; backup integrity-hashed and stored securely; Join Key held in separate escrow.	Backup excludes Join Key by design - document escrow procedure. Backup security = handled off-device.
SR/CR 7.4	Control system recovery and reconstitution - Support recovery to a known secure state.	Recover via **DTM/Asset Vision Basic** re-download of the saved offline config after a **Master Reset** (Extras/Service -> Resets = device reboot, used for F240.024/025 confdb corruption) or **Load Factory Settings** (Extras -> Load Factory Settings). After sensor/electronics swap use **DIP SW1 pos.1 replace-mode + SW2 select + power-cycle + auto-configuration (SW1 & SW2 up at power-on)** to restore params. Reconstitute secure state by **re-provisioning per-device unique Join Key + Network ID** (not the factory default) and re-enabling the **hardware write-protect switch**. **Ext. tools:** ABB **DTM/handheld** for reload + key re-provisioning; sha256sum to verify restored config matches escrowed baseline.	Post-reset device reloads baseline config, joins with the non-default per-device key, and write-protect re-enabled; restored config hash matches backup.	Load Factory Settings reverts Network ID to 0xABB / Join Key to WIRELESSFIELDKEY - MUST re-key after any factory reset.
SR 7.5	Emergency power - Support transition to/from emergency power without affecting security.	**N/A.** The 266 WirelessHART is self-powered by an internal **3.6V Li-SOCl2 D-cell (TADIRAN SL 2880 / ABB DR3051)** with no external/emergency power feed; there is no power-transition event to protect. Battery replacement uses **Service -> Replace battery mode** and keys/config persist in non-volatile memory (security state unchanged across battery swap). Emergency/backup power is a facility-level concern for the upstream gateway/DCS, not this instrument.	**N/A** - justification recorded (not assessed as a control)	**N/A.** Battery-only field device; keys/config are non-volatile, survive battery change.
SR/CR 7.6	Network and security configuration settings - Manage and verify security configuration.	Verify security config through native menus: **Communication/Easy Set-up** -> confirm **Network ID ? 0xABB (2747)** default and a **per-device unique Join Key** is set (Key1-4 HEX, capitals) - Join Key is write-only/not read-back, so verify by successful join not by reading it. **Diagnostics/Device Set-up** -> confirm **Input Simulation (C160.030) OFF** and burst config matches baseline. **Device Info** -> record HW Rev/SW Rev/display rev. Enable **hardware write-protect switch** (under ID plate, 90° CW) + optional **Display-menu protection password** to lock the verified config. **Test:** attempt a param write with write-protect on -> expect '! Oper Disabled'. **Ext. tools:** ABB **DTM/handheld** to read/compare settings; nRF-Sniffer/Wireshark to confirm the device joined on the intended Network ID (passive); maintain the baseline in a controlled config register (e.g., spreadsheet + sha256 of DTM export).	Non-default Network ID + unique Join Key verified via successful join; simulation off; write-protect + password enforced (write blocked); Device Info revs recorded against baseline.	Join Key non-readable by design - verify via join, not read-back. Confirm join not on default 0xABB/WIRELESSFIELDKEY.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native HMI/DTM/handheld steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.7	Least functionality - Restrict to least functionality (disable unused ports/services).	Fixed-function device: **no Ethernet/IP, no TCP-UDP ports, no web/CLI/SSH/SNMP/Modbus** to disable - attack surface is only the WirelessHART radio + wired HART maintenance loop + local buttons. Minimize by: **turning OFF Input Simulation (C160.030)** via **HART configurator -> return to normal mode**; disabling unused **Burst** messages (Communication -> Burst); enabling the **hardware write-protect switch** which disables **Z/S push buttons** and blocks config overwrite; restricting HART **multidrop poll address** as per plant policy. Physically secure the ID plate (covers write-protect + Z button) and DIP switches. **Ext. tools:** ABB **DTM/handheld** to enumerate/disable enabled features (simulation, burst); ReadOnlyEnum.py-style checklist to record enabled-services inventory; nRF-Sniffer/Wireshark to confirm no unexpected extra traffic beyond configured burst/join.	Simulation disabled; only required burst msgs enabled; write-protect ON (buttons disabled); no IP services exist to disable - surface documented as radio+HART-loop+buttons only.	No IP ports by product design (transmitter has no IP stack). Simulation left ON = SL-3 finding (spoofed values).
SR/CR 7.8	Control system component inventory - Maintain a component inventory.	Populate inventory from native identifiers: **Device Info** menu (sensor type, HW Rev, SW Rev, sensor limits, min span, display rev), nameplate (model/order code W-9, serial, FCC ID 2AC5O-WICB, IC 12311A-WICB, battery code), and **Long Tag (32-char, unique)** set via **Communication** menu. Pull the same via **DTM 'About'** (EDD/DTM driver rev, e.g. HART DTM history 7.1.50). Cross-check the live radio inventory on the **gateway/network manager** (joined-device list by Long Tag + Network ID). **Ext. tools:** ABB **DTM/Asset Vision Basic** device-identification export; passive OT-discovery via **Nozomi Guardian / Claroty / Dragos / Tenable.ot** on the gateway's Modbus-TCP/HART-IP uplink to auto-inventory WirelessHART field devices; nRF-Sniffer to confirm the joined device's presence on the mesh.	Inventory record holds model/order-code, serial, HW/SW rev, EDD/DTM rev, FCC/IC IDs, unique Long Tag and Network ID; reconciles with gateway joined-device list and passive OT discovery.	Live network inventory reconciled at gateway (device has no IP to be scanned directly). Confirm exact FW/EDD rev from nameplate + DTM at assessment.

External Test Tools - how to use

Tool / method	Verifies	How to use - steps / example	Constraints
ABB DTM in FDT frame (fdtCONTAINER / PACTware) + 266 WiPressure DTM	Wireless config verification, Network ID/Join Key change, config backup/restore, network diagnostics, identity/Long-Tag, key always-on AES-128 (1.2, 1.4, 1.5, 1.6, 4.1, 4.2, 7.3, 7.4, 7.6, 7.8)	Connect HART modem (e.g. Viator USB) to **Field Terminals** loop; add 266 WiPressure DTM in FDT frame; go **Communication -> Wireless Config -> Network Settings** to set **Network ID** (decimal) and **Key1-4** (HEX, write-only); **File -> Save** for offline config backup; **Network Diagnostics** for Join complete / neighbor RSSI. Confirm DTM 'About' for driver rev (ref 7.1.50).	Authorized maintenance window; write actions modify live device - verify Write-Protect state first; Join Key not readable back (positive control).
ABB Asset Vision Basic v1.00.17+	Config backup/save, offline config, Long-Tag uniqueness, parameter review, recovery re-download (1.4, 7.3, 7.4, 7.8)	Install AVB (>=v1.00.17); connect via HART modem to loop terminals or via gateway (needs LONG TAG); **File -> Save** to export config to separate medium; **Parametrize** to review; re-download saved config after Master Reset/Load Factory Settings.	Authorized window; wired HART modem or gateway path; changes require live device.
ABB DHH805 / Emerson 375-475 HART handheld (266 EDD, HART 7)	No per-user auth on local access, device identity/poll address, join-key write-only, factory reset/purge, write-protect behavior, simulation removal (1.1, 1.4, 1.5, 1.10, 2.1, 2.3, 4.2, 7.4)	Set handheld to poll multidrop/addr 1; **DD navigation -> Wireless Config -> Network Settings** to enter Network ID/Key1-4 and confirm Join Key cannot be read back; **Extras -> Load Factory Settings / Lock-Unlock Device / Start Squawk**; verify **C160.030 Input Simulation** can be cleared to normal mode.	Requires 266 EDD (HART 7) loaded; authorized window; physical loop connection under Field Terminals cover.
Integral LCD HMI keypad / TTG + physical inspection	Least functionality (burst OFF, simulation OFF), write-protect switch, protection password, device info inventory, no login banner, factory reset (1.7, 1.12, 2.1, 2.5, 2.8, 7.6, 7.7, 7.8)	Menu: **Easy Set-up/Communication** (Network ID, Join Key, Tags); **Device Set-up** (reset to default, Write Protection); **Display** (set protection password); **Diagnostics** (NE107 codes, Historic Info); **Device Info** (HW Rev/SW Rev, sensor type). Physically inspect ID plate: **hardware Write-Protect switch** (turn 90° CW) disables Z/S buttons.	Local physical access only; press Z >2s to wake; magnetic screwdriver not permitted; instrument must be live to toggle write-protect.
WirelessHART Network Manager / Gateway web UI (e.g. Pepperl+Fuchs / Emerson 1420)	Device join authentication, per-device Join Key provisioning, Active Advertising control, deauthorize/blacklist device, key rotation, network time (TDMA), audit at boundary (1.2, 1.6, 2.6, 4.1, 6.1, 7.1, 7.6)	In gateway web UI: provision **per-device unique Join Key + EUI-64**; enable **Active Advertising** only during commissioning then disable; view **Join status/neighbor table**; configure **key rotation** per policy; remove/blacklist decommissioned device; verify TDMA network time source.	Separate product (not the transmitter); authorized window; gateway holds the network manager - confirm exact model/firmware.

Tool / method	Verifies	How to use - steps / example	Constraints
Gateway TLS/crypto validation - testssl.sh / sslyze / openssl	Boundary TLS on gateway->host (HART-IP/TLS wrapper), cipher strength, cert validity (1.8, 4.1, 4.3 - boundary only)	Against gateway host interface: `testssl.sh <gw-ip>:5094` or `sslyze --regular <gw-ip>:443`; `openssl s_client -connect <gw-ip>:<port> -tls1_2` to inspect cert/cipher. Confirm TLS1.2+ and no weak ciphers on the HART-IP/host hop.	Runs against the GATEWAY, not the transmitter (device has no IP stack); authorized window; read-only.
Gateway network exposure scan - Nmap (+ ICS NSE) / ReadOnlyEnum.py	Boundary port/service enumeration, least functionality at gateway (Modbus TCP 502, HART-IP 5094), unused-service disable (5.1, 5.2, 7.7 - boundary)	`nmap -sS -sV -p 1-65535 <gw-ip>` and `nmap --script modbus-discover,banner -p502 <gw-ip>`; run asset-owner **ReadOnlyEnum.py** read-only to inventory exposed services/interfaces on the gateway/EWS. Transmitter itself has NO IP - record **N/A.**	GATEWAY/EWS only; read-only; authorized window - do NOT scan the field transmitter (no TCP/UDP stack).
802.15.4 / WirelessHART RF capture - Ubiqua Protocol Analyzer / TI SmartRF Sniffer + Wireshark (WirelessHART dissector)	Confirm AES-128 CCM encryption always-on, MIC integrity, no plaintext payloads, FHSS/channel hopping, replay resistance (2.2, 4.1, 4.3, 7.1)	Capture 2.4 GHz 802.15.4 with Ubiqua or TI CC2531/CC2652 sniffer; open in Wireshark with WirelessHART/IEEE 802.15.4 dissector; verify payloads are ciphertext (no readable PV), MIC present, and channel hopping across 15/16 channels. Attempt replay of captured frame - must be rejected by MIC/nonce.	Passive RF capture (receive-only); replay test only in ISOLATED/lab with authorization; requires 2.4 GHz capture radio.
RF spectrum analyzer / jamming resilience harness (e.g. Ekahau / handheld SA + interference generator)	Essential function decoupled from radio, DoS/jamming resilience, channel blacklisting, resource-limit under RF flood (7.1, 7.2)	In lab RF chamber: inject 2.4 GHz interference on active channels; confirm mesh re-routes / blacklists channel and that local **4-20 mA / LCD pressure output keeps updating** independent of radio. Observe TDMA slot bounding (10 ms slots).	ISOLATED RF chamber only (jamming is illegal on live spectrum); authorized; measures availability of essential function, not confidentiality.
WirelessHART join/key attack harness - default-key join attempt (lab HART/WirelessHART toolkit)	Default/hardcoded Join Key replaced, per-device unique keys enforced, rogue-join rejected (1.2, 1.5, 2.2, 7.6)	In ISOLATED test net, attempt to join a spare 266 using default **Network ID 0xABB (2747)** + default Join Key `57495245 4C455353 4649454C 444B4559`; provisioned/hardened device MUST reject (F205.014 Join Failure). Repeat with wrong per-device key to confirm rejection.	ISOLATED/lab only with spare device; authorized; never on production mesh.
python-hart / HART loop client + HART cmd 48 poller (e.g. hcli / custom pyHART)	Diagnostic/status readout, NE107 fault reporting, simulation-active detection, burst config audit (2.8, 2.10, 6.2, 7.7)	Over FSK loop via HART modem, poll **cmd 48** (additional device status) and cmds 1/2/3 to read NE107 codes (F240.024/025, F210.015, C160.030 sim active) and burst config; confirm F-class failure drives fail-safe/alarm output.	Wired loop, authorized window; read-focused; sim/burst toggles are write actions - do under write-protect governance.
boofuzz (HART/WirelessHART command fuzzing)	Input validation / robustness of HART command parser against malformed frames (2.4-robustness, 7.2)	In ISOLATED lab, drive a boofuzz session over the HART maintenance loop against a spare 266, mutating HART command payloads (cmds 1/2/3/9/33/48); monitor for hang/reset (F240 confdb corruption) vs graceful reject.	ISOLATED/lab, spare device only; authorized; may corrupt config (recover via Master Reset + DTM re-download).
Passive OT monitoring - Nozomi Guardian / Claroty / Dragos (WirelessHART gateway visibility)	Asset inventory, anomaly/flood detection, zone/conduit monitoring at boundary, SIEM alerting compensations (2.9, 5.1, 6.1, 6.2, 7.8)	SPAN/tap the gateway->DCS link (Modbus TCP 502 / HART-IP); import passive inventory (Long-Tag, EUI-64, model); create alerts for gateway-spoofing/flooding/desync and forward to SIEM (Splunk/Wazuh).	Passive SPAN/tap at gateway/host network; cannot see inside AES mesh directly; compensating control for on-device logging gaps.
SIEM/syslog collector - Splunk / Elastic / Wazuh (nc -lu 514 for quick test)	Audit storage, retention, security-event monitoring at boundary (2.9, 2.11, 6.1, 6.2)	Point gateway/network-manager syslog to collector; `nc -lu 514` to confirm receipt; build retention policy + alerts for join failures, key rotation, gateway auth events. Transmitter has no syslog/NTP - record as gateway-level compensating control.	Boundary/gateway only; authorized; transmitter cannot emit logs (fixed-size Historic Info only).
sha256sum / config-diff baseline compare	Backup integrity and config-change detection for saved offline configs (7.3, 7.4, 7.6)	After DTM/AVB **File -> Save**, `sha256sum config.export` and store hash; on restore/audit, re-hash and diff against baseline to detect drift (Network ID/burst/tags/write-protect state).	Read-only on exported files; store hashes off-device in controlled repo.

SL-3 target = protection against intentional misuse by skilled attackers with moderate resources. This transmitter has no IP stack, user accounts, RBAC, login, audit log, or NTP; its security rests on WirelessHART AES-128 CCM (always-on, non-disableable), the Network ID + 128-bit Join Key join model (Join Key is write-only / cannot be read back), the hardware write-protect switch, and the optional HMI protection password. CRITICAL SL-3 actions: (1) change the DEFAULT Network ID

0xABB (2747) and (2) REPLACE the hardcoded default Join Key 57495245 4C455353 4649454C 444B4559 ('WIRELESSFIELDKEY') with PER-DEVICE UNIQUE join keys, (3) enforce the hardware write-protect switch + password, (4) disable Input Simulation (C160.030) and unneeded Burst messages, (5) push audit logging / TLS / time-sync / port hardening onto the upstream WirelessHART Gateway. Verify all firmware/EDD/DTM versions from the nameplate + DTM 'About' at assessment time; confirm signed-firmware/secure-boot posture with ABB PSIRT.